

CLOUD-5 — #335: expired and revoked keys stop reading as "Valid"

Batch of 2026-08-26 · merge order 5 of 5 (wire-format change — lands last so the protocol bump sits on top of a quiet main).

```
task_id: gv-335-cloud-5
issue: 335
branch: cloud/335-signature-status
base: main          # rebase onto latest main before opening the PR
adr_number: 0088     # ASSIGNED — wire-contract change; it gets an ADR.
sign_commits_as:
  name: Claude_Max
  email: 262510778+tom2025b@users.noreply.github.com
  # per-commit, ALWAYS: git -c user.name=Claude_Max -c
  user.email=262510778+tom2025b@users.noreply.github.com commit ...
allowed_paths:
  - crates/git-vista-protocol/src/**
  - crates/git-vista-server/src/handlers/tags.rs
  - crates/git-vista/src/**          # ONLY the tag-band display of the new
statuses; nothing else in the frontend
  - docs/adr/
forbidden_paths:
  - crates/git-vista/src/features/stash/** # another crew's lane today —
absolutely not
  - ci/browser/**
deliverables:
  - branch pushed, PR opened with "Closes #335"
  - ADR 0088 + index entry
```

Environment truths — read before your first test run

- **~320 server tests fail in your container on unmodified main** (no Landlock). Baseline first; only the diff is yours; both counts in the PR body.
- **cargo build -p git-vista-server --bin gv-sandbox before any server test run.**
- **The browser leg cannot run in your container, and your change touches frontend display** — so this line in the PR body is load-bearing, not boilerplate: "ci/browser/run.sh unrun — cloud container; frontend tag-band display needs the owner's browser-leg run before merge."
- Frontend compile check that DOES work in your container: `cargo clippy -p git-vista --target wasm32-unknown-unknown -- -D warnings` (the wasm target is installed by rustup in the container; if it is not, `rustup target add wasm32-unknown-unknown` first, and say so).

The defect (found by adversarial review of #237, filed as #335)

`classify_verify_tag_output` (`crates/git-vista-server/src/handlers/tags.rs:598`) maps `gpg status` lines onto `SignatureStatus` (`crates/git-vista-protocol/src/dto.rs:1194`) — five variants: `Unsigned`, `Valid`, `Invalid`, `UnknownKey`, `Unverifiable`.

Correction to the issue text, verified against 405a7644 — read this before you start, the two cases are NOT the same shape:

gpg status	Meaning	Today reports	Handled?
EXPKEYSIG	crypto passed; signing key has since expired	Valid	deliberately — <code>tags.rs:613</code> maps it alongside <code>GOODSIG</code>
EXPSIG	crypto passed; the signature itself expired	Valid	deliberately — same arm
REVKEYSIG	signature by a REVOKED key — often compromise	Unverifiable	no — genuinely absent from the file; reaches the no-recognised-line fallthrough

The issue says all three "have nowhere to go". That is true only of `REVKEYSIG`. The two expired statuses are consciously folded into the `GOODSIG` arm at `tags.rs:613`, and the comment above it at `:608-612` states the reasoning: the cryptographic check itself passed (`gpg` emits them exactly where it would emit `GOODSIG`), and there is no variant for "passed, but expired", so it reports the same fact `GOODSIG` does.

This changes your job in two ways: - That comment becomes `FALSE` the moment you add the variants. Replacing it with one that states the new mapping is part of the work, not a nicety — a stale rationale is how the next reader concludes the fold was accidental. - `REVKEYSIG` is a true fallthrough and is the more serious half: a revoked key reading as a generic "could not check" is the one case where the honest answer is closer to alarm than to a shrug.

Re-verify all of the above against your own checkout before building — these citations were checked on 2026-08-26 and can drift.

The job

1. **Extend `SignatureStatus`** with distinct variants for the three (the issue's framing suggests `ValidExpiredKey` / `ValidExpiredSignature` — or one `Expired { what }` — and `Revoked`; pick the shape that keeps the frontend match exhaustive and the ADR argues it). This is a wire-format change: follow whatever versioning discipline the protocol crate's module docs prescribe (read how #506's v7 bump was done and match it — including whether a bump is required for an additive enum variant, which the protocol docs answer; do not guess).
2. **Classify the three `gpg` statuses** in `classify_verify_tag_output`: split `EXPKEYSIG` / `EXPSIG` out of the `GOODSIG` arm at `:613`, kill the `REVKEYSIG` fallthrough explicitly, and **rewrite the `:608-612` rationale comment** so it describes the mapping that now exists rather than the one it replaced. Preserve the `BADSIG`-outranks-everything precedence

the surrounding doc comment (:586-596) argues for — a revoked-key line must not be able to downgrade a BADSIG, exactly as NO_PUBKEY cannot today.

3. **Frontend tag band:** display the new statuses with wording that says what happened — "signed, key since expired" is information; "expired" is ambiguity. Revoked reads as a warning, not a shrug. Touch ONLY the tag-band display path.
4. **Tests:** classifier tests from verbatim gpg status-line fixtures for all three; an exhaustiveness guard so the NEXT unhandled gpg status cannot silently fall through to Unverifiable again (if the current code's fallthrough is deliberate, the guard is a test pinning the full list of statuses it may absorb).
5. **Mutation-prove two different ways:** revert REVKEYSIG to the fallthrough; then swap the two expired classifications. Red at different assertions, byte-identical restore verified.

Acceptance

1. Three statuses classify distinctly; wire change follows the protocol crate's own bump discipline, ADR 0088 records shape + reasoning.
2. Mutation evidence in the PR body (two red lines, verbatim).
3. cargo fmt --all · clippy native AND wasm targets -D warnings · server suite zero new failures vs baseline · protocol crate tests green.
4. PR body: baseline counts, the load-bearing browser-leg line, ADR summary, your session tag.

Written by fable · 2026-08-26 · truth-check the classifier against your checkout before building.